GOOGLE CLOUD ZERO-TRUST AI SECURITY & ISO/IEC 42001 AIMS GOVERNANCE PLATFORM

# Aseguramiento, Gobernanza y Auditoría Continua de IA

Plataforma integral para evaluar, auditar y blindar arquitecturas de Inteligencia Artificial Empresarial (GenAI, LLMs, Agentes Autónomos, MCP y RAG) bajo estándares mundiales **OWASP AI-SVS v1.0 (Nivel L2/L3)** e **ISO/IEC 42001:2023**.

OWASP AI-SVS V1.0 (12 CAPÍTULOS) | ISO/IEC 42001:2023 AIMS | BORDE CLOUD IAP ZERO-TRUST (C04.3) | VERTEX AI GEMINI 3.8 FLASH (ADC SIN LLAVES)

INTEGRIDAD SHA-256 (C01.4) | DEFENSA CRESCENDO (C02.10) & ANTI-DOW (C11.1)

EL PROBLEMA A RESOLVER

# El Punto Ciego Crítico en la Adopción Empresarial de GenAI

Las organizaciones despliegan modelos generativos, flujos agénticos, herramientas MCP y pipelines RAG sin verificación arquitectónica ni gobernanza ISO 42001.

### ⚠ Despliegue Acelerado sin Gobierno

El **13% de las organizaciones** ya reportó brechas en modelos o aplicaciones de IA, y el **97%** de ellas carecía de controles de acceso adecuados para IA (IBM, 2025).

### ⚠ Superficie Multi-Turno y Agéntica

Pipelines RAG, servidores MCP y agentes introducen vectores críticos: **Inyección Multi-Turno Crescendo** ( `C02.10` ), **Envenenamiento Normativo/Vectorial** ( `C01.4` ) y SSRF/IMDS ( `C04.3` ).

### ⚠ Silo entre CISO y Ciencia de Datos

Los equipos de seguridad carecen de herramientas para auditar grafos de agentes, manifiestos MCP ( `C10.1` ) y ACLs vectoriales ( `C08.1` ) antes de producción.

### Brecha de Gobernanza Operativa (ISO/IEC 42001)

Dificultad para operacionalizar los controles de **ISO/IEC 42001:2023** —como Políticas Corporativas de IA ( `A.2.1` ), Canal Ético Confidencial ( `A.3.3` ), Inventario de Activos IA ( `A.4.1` ) y Apelación Humana ( `A.5.2` )— en el ciclo de ingeniería.

### Proliferación de "Shadow AI" y Denial of Wallet

Invocaciones externas sin cuotas, comparación insegura de tokens ( `C05.3` ), cuentas de servicio sobre-privilegiadas ( `C05.2` ), falta de presupuestos Anti-DoW ( `C11.1` ) y exposición de logprobs ( `C11.4` ).



Fuente: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

IMPACTO DE LA INACCIÓN

# El Costo Real de Omitir la Auditoría Preventiva de IA

Operar sistemas de IA sin verificación expone a la organización a sanciones financieras, legales y operativas severas.

**€35M**
o 7% de facturación global anual en multas estatutarias del **EU AI Act**

**$4.88M**
Costo promedio global de una brecha de datos corporativa (IBM Security 2024)

**13%**
de las organizaciones reportó brechas en modelos o apps de IA (IBM 2025)

**97%**
de ellas carecía de controles de acceso adecuados para IA (IBM 2025)

### Exfiltración de Secretos, IMDS y PII

Ataques multi-turno crescendo y SSRF diseñados para extraer metadatos cloud ( `169.254.169.254` ), llaves API o registros entre inquilinos cuando faltan ACLs pre-recuperación ( `C08.1` ).

### Sanciones Regulatorias y Suspensión

Incumplimiento de controles AIMS ISO/IEC 42001, purga en cascada ARCO (LFPDPPP/GDPR) o retracto comercial del Art. 56 LFPC provoca suspensiones y litigios.

### Decisiones Algorítmicas Inapelables

Dictámenes alucinados o decisiones automatizadas sesgadas sin canal de apelación humana ( `ISO 42001 A.5.2` ) ni canal ético ( `A.3.3` ) erosionan la confianza institucional.

NUESTRA SOLUCIÓN

# AegisAI: Aseguramiento Integral y Automatizado de IA

Transformando semanas de auditoría manual en verificación determinística respaldada por evidencia textual y código de remediación.

### 🛡 Verificación Multi-Estándar Shift-Left

AegisAI inspecciona documentos de arquitectura, PDFs, paquetes ZIP, microservicios y telemetría GCP en vivo contra **OWASP AI-SVS v1.0** e **ISO/IEC 42001:2023** simultáneamente.

- Evaluación Map-Reduce determinística con esquemas enum estrictos por lote ( `buildBatchChaptersSchema` ).
- Citación textual obligatoria ( `textoEvidencia` y `fuenteEvidencia` ).
- Enmascaramiento DLP pre-inferencia y bloqueo de inyección multi-turno crescendo ( `C02.10` ).

### ⚡ Arquitectura Remediada al 100% y Recetario Completo

Más allá del diagnóstico, AegisAI sintetiza una **Especificación de Arquitectura Corregida Drop-in** (Sección 3) más un **Recetario Técnico Completo** (Sección 4) para cada hallazgo.

- Renderiza todos los parches `1..N` sin truncamiento, incluso en auditorías con más de 35 hallazgos.
- Resúmenes por oración completa y detección precisa de lenguaje ( `typescript` , `hcl` , `yaml` , `python` , `bash` ).
- Exportación ejecutiva en PDF y Markdown lista para comités de certificación e ingeniería.

### 1. Integridad Criptográfica (C01.4)

Snapshots normativos verificados al arranque contra un manifiesto SHA-256 ( `integrity-manifest.json` ).

### 2. GCP Live Scanner sin Llaves (C05.2)

Inspección de solo lectura sobre Vertex AI, Cloud Run, IAM y Secret Manager con credenciales efímeras.

### 3. Telemetría Continua AIMS (C08.4)

Monitoreo en tiempo real de cobertura de citación, fidelidad JSON y postura de controles.

MATRIZ DE CUMPLIMIENTO

# Soporte Multi-Estándar y Gobernanza AIMS ISO/IEC 42001

Evaluación simultánea de estándares técnicos globales de seguridad en IA, sistemas de gestión y leyes de privacidad.

| Estándar / Marco | Alcance Técnico y de Gobernanza | Controles Clave Verificados y Aplicados por AegisAI | Nivel |
|---|---|---|---|
| **OWASP AI-SVS v1.0** | Estándar de Verificación de Seguridad en IA (12 Capítulos) | `C01.4` Manifiesto SHA-256, `C02.10` Guardia Crescendo, `C04.1` Contenedor Read-Only, `C04.3` Cloud IAP y Bloqueo SSRF, `C05.2–C05.4` Auth en Tiempo Constante e IAM, `C08.1/C08.4` ACLs RAG, `C09.4` Sagas, `C10.1–C10.5` Seguridad MCP, `C11.1/C11.4` Anti-DoW y Logprobs Off, `C12.2` Alertas SIEM. | L1 / L2 / L3 LISTO |
| **ISO/IEC 42001:2023** | Sistema de Gestión de IA (AIMS Cláusulas 4–10 y Anexo A) | `Cláusula 4.1/4.2` Contexto y Stakeholders, `Cláusula 5/A.2.1/A.2.3` Política Corporativa IA, `Cláusula 7/A.3.3` Competencia y Canal Ético, `A.4.1` Inventario IA, `A.5.1–A.5.3` Evaluación de Impacto y Apelación Humana, `Cláusula 9` KPIs y Auditoría Interna, `A.9.1/A.9.2` Uso Aceptable. | 54 CONTROLES |
| **Regulación Mexicana (2026)** | Protección al Consumidor (LFPC) y Datos Personales (LFPDPPP) | Transparencia algorítmica, prevención de patrones oscuros, retracto de 5 días (Art. 56 LFPC), purga en cascada ARCO y enmascaramiento DLP. | ESTATUTARIO LOCAL |
| **Marco BYOF Personalizado** | *Bring Your Own Framework* (Multi-Inquilino) | Ingesta autenticada por administrador ( `C05.3` ) con verificación SHA-256 ( `C01.4` ) y pre-filtrado ACL por dominio de inquilino ( `allowedDomains` , `C08.1` ). | AISLADO POR TENANT |

**Motor Map-Reduce Cruzado sin Colisiones:** Evalúa más de 103 controles combinados de OWASP AI-SVS e ISO/IEC 42001 en lotes paralelos usando enums de capítulo restringidos para que las Cláusulas 9/10 y Anexo A.9/A.10 jamás colisionen con C09/C10.

ARQUITECTURA DE SOFTWARE

# Arquitectura Zero-Trust de 4 Capas y Defensa en Profundidad

Arquitectura serverless endurecida en Google Cloud Run detrás de Identity-Aware Proxy (IAP) con inferencia Vertex AI sin llaves.

### 1. Perímetro y SPA

- **Cloud IAP** ( `--no-allow-unauthenticated` )
- **React 19 + TS + Vite**
- Lista blanca OAuth 2.0 en Firebase Auth ( `google.com` , `example.com` )
- Avisos visibles ISO 42001 de Política, Apelación ( `A.5.2` ) y Canal Ético ( `A.3.3` )

### 2. Capa API Endurecida

- **Contenedor Read-Only** ( `chmod -R a-w /app` , `C04.1` )
- Tokens en tiempo constante ( `crypto.timingSafeEqual` , `C05.3` )
- Firebase Admin `verifyIdToken()`
- Guardia DNS Rebinding ( `C10.5` ) y Firma MCP ( `C10.1` )
- Cuotas Anti-DoW ( `C11.1` )

### 3. Motor IA y Guardrails

- **Vertex AI** ( `gemini-3.8-flash` ) vía ADC sin llaves
- SA de mínimo privilegio ( `aegis-runner-sa` : cero `roles/viewer` , `C05.2` )
- Detector Multi-Turno Crescendo ( `C02.10` )
- `responseLogprobs: false` ( `C11.4` )
- Bloqueo SSRF/IMDS ( `C04.3` )

### 4. Datos, Integridad y Sagas

- **Cloud Firestore** ( `aegis-ai-db` ) vía Admin SDK
- 308/308 pruebas `firestore.rules`
- Auditorías inmutables ( `allow delete: if false` ) y ACLs `ownerUid` ( `C05.4` )
- Manifiesto SHA-256 ( `C01.4` )
- Sagas Compensatorias ( `C09.4` )

### Aislamiento Zero-Trust y Alertamiento Estructurado de Seguridad (C12.2):

El estado en tiempo de ejecución se persiste exclusivamente en Firestore ( `system_config/admin_settings` ) y caché efímero `/tmp/aegis-runtime-cache` . Cada evento de seguridad (escalación de prompt injection, bloqueo SSRF, fallo de token, exceso de cuota DoW, reversión de saga) emite una alerta JSON estructurada ( `aegis-security-alerting-c12-2` ) hacia Google Cloud Logging.

EJECUCIÓN OPERATIVA

# Flujo del Auditor: De la Ingesta al Blindaje al 100%

Ciclo determinístico de aseguramiento en 6 etapas con supervisión humana integrada y remediación automatizada.

1 **Ingesta Autenticada y Guardrails Pre-Vuelo**
El usuario corporativo (verificado por Cloud IAP + Firebase ID Token) carga PDFs/ZIPs; `inspectPromptAndTrackSession` ( `C02.10` ) y DLP sanean la entrada.

2 **Contexto Verificado SHA-256 y Filtrado por Tenant**
Se validan los snapshots normativos contra `integrity-manifest.json` ( `C01.4` ) y se filtran los marcos por `tenantDomain` ( `C08.1` ).

3 **Evaluación Determinística Map-Reduce en Vertex AI**
`gemini-3.8-flash` ( `temperature: 0.0` , `responseLogprobs: false` , timeout 180s) evalúa cada lote bajo enums estrictos de capítulos.

4 **Tablero Ejecutivo y Apelación Humana (ISO A.5.2)**
Gráficos radar interactivos, madurez L1/L2/L3 y flujo directo de Apelación de Dictamen / Revisión Humana ( `ai-appeals@aegisai.enterprise` ).

5 **Arquitectura Remediada al 100% y Recetario Completo**
Sintetiza la Sección 3 drop-in + Sección 4 Cookbook para todos los hallazgos `1..N` con etiquetas precisas ( `typescript` , `hcl` , `yaml` , `python` , `bash` ).

6 **Persistencia Inmutable y Saga Compensatoria**
Guardado en Firestore con atribución `ownerUid` / `tenantDomain` ( `C05.4` ), protección `runCompensatingSaga` ( `C09.4` ) y registro de KPIs AIMS ( `C08.4` ).

ESPECIFICACIONES Y VERIFICACIÓN DEVSECOPS

# Benchmarks de Seguridad Verificados y Postura en Producción

Validado continuamente mediante pruebas unitarias de reglas Firestore, suites OWASP AI-SVS y chequeos preflight en Cloud Run.

**308/308**
Pruebas unitarias de Cloud Firestore Security Rules aprobadas ( `projects:test` )

**6 / 6**
Snapshots normativos verificados con SHA-256 al arranque ( `C01.4` )

**0**
Secretos expuestos o roles IAM amplios ( `roles/viewer` revocado, `C05.2` )

**100%**
Generación sin truncamiento del recetario de parches para los 35+ controles

## Postura Endurecida en Cloud Run y Contenedor

- **Contenedor Inmutable (C04.1):** Usuario no-root `aegisuser` con `chmod -R a-w /app`.
- **Perímetro Zero-Trust (C04.3):** Cloud IAP + `--no-allow-unauthenticated` + egreso privado VPC + bloqueo SSRF/IMDS.
- **Secret Manager y Auth Constante (C05.3):** `ADMIN_API_TOKEN` validado vía SHA-256 + `crypto.timingSafeEqual`.
- **Protección FinOps Anti-DoW (C11.1):** Límites por usuario de tasa, concurrencia (3) y presupuesto 24h de 500k tokens.

## Observabilidad, Privacidad y Gobernanza AIMS

- **Cloud Logging Estructurado (C12.2):** Alertas `WARNING` / `CRITICAL` en tiempo real ( `aegis-security-alerting-c12-2` ).
- **Telemetría Continua AIMS (C08.4 / Cláusula 9.1):** Métricas de citación y fidelidad JSON en `/api/admin/aims-telemetry`.
- **Zero Data Retention (ZDR):** Garantías empresariales de privacidad en Vertex AI.
- **Suite Documental Bilingüe:** 8 Manuales en Inglés y 8 en Español + Manual AIMS ISO 42001 compilados en PDF.

TRAZABILIDAD INTEGRAL DE REMEDIACIÓN

# Controles OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Implementados

Controles arquitectónicos y de gobernanza aplicados en código, contenedor, perímetro cloud y políticas AIMS.

## Controles Técnicos OWASP AI-SVS v1.0 (17 Dominios Endurecidos)

- **C01.4 Integridad Normativa:** `verifyNormativeSnapshotsIntegrity()` con manifiesto SHA-256 al arranque.
- **C02.10 Defensa Crescendo:** `inspectPromptAndTrackSession()` bloquea escalación multi-turno (HTTP 422).
- **C04.1 & C04.3 Infraestructura:** `/app` solo lectura ( `chmod -R a-w` ), Cloud IAP, egreso VPC y bloqueo SSRF/IMDS `validateOutboundEndpoint()` .
- **C05.2, C05.3 & C05.4 Auth/IAM:** Revocación de `roles/viewer` en `aegis-runner-sa` , `crypto.timingSafeEqual` , verificación de Firebase ID token y ACLs `ownerUid` .
- **C08.1 & C08.4 RAG/Grounding:** Pre-filtrado ACL por dominio de inquilino y telemetría continua.
- **C09.4 & C10.1–C10.5 Agentes/MCP:** `runCompensatingSaga()` , firma MCP Ed25519/HMAC, OAuth 2.1 PKCE y `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` y `emitSecurityAlert()` .

## Controles de Gobernanza AIMS ISO/IEC 42001:2023 (18 Cláusulas y Anexo A)

- **Cláusula 4.1 & 4.2 Contexto y Stakeholders:** Matriz de cuestiones internas/externas, rol de proveedor de aseguramiento IA y partes interesadas.
- **Cláusula 5.1, 5.2, A.2.1 & A.2.3 Liderazgo y Política IA:** Política Corporativa de IA aprobada por dirección con revisión anual.
- **Cláusula 7.2, 7.3 & A.3.3 Competencia y Canal Ético:** Capacitación por rol y canal confidencial de denuncias ( `ai-ethics-whistleblower@aegisai.enterprise` ).
- **A.4.1 Inventario de Recursos y Herramientas:** Catálogo de modelos, corpus normativos, cuentas de servicio y secretos KMS.
- **A.5.1, A.5.2 & A.5.3 Evaluación de Impacto y Apelación:** Metodología AIIA, umbrales cuantitativos y canal de apelación humana ( `ai-appeals@aegisai.enterprise` ).
- **Cláusula 9.1–9.3 & A.9.1/A.9.2 Aseguramiento y Uso:** KPIs continuos, auditoría interna semestral, revisión directiva y avisos de uso aceptable.

EVOLUCIÓN Y ROADMAP

# Siguientes Pasos en la Ingeniería de AegisAI

Hoja de ruta para consolidar el aseguramiento autónomo de Inteligencia Artificial empresarial.

Q4 2026 • CORTO PLAZO

### Compuertas CI/CD Shift-Left

**GitHub Actions** y **GitLab CI Runners** oficiales para bloquear automáticamente *pull requests* con vulnerabilidades de prompt injection, manifiestos MCP sin firma o vectores sin cifrar.

Q1 2027 • MEDIANO PLAZO

### Auditoría de Grafos Multi-Agente

Módulo especializado para auditar flujos de agentes autónomos complejos (LangGraph, CrewAI, AutoGen): validación de fronteras de autorización, sagas compensatorias y sandboxing de memoria.

Q2 2027 • LARGO PLAZO

### Auto-Remediación con IaC

Síntesis automatizada de módulos de **Terraform** y **Helm Charts** que apliquen políticas de Cloud IAP, VPC Service Controls y Cloud Armor en un clic.

### 🎯 Conclusión: Seguridad y Gobernanza que Aceleran la Innovación

AegisAI proporciona la **certeza arquitectónica, integridad criptográfica y gobernanza ISO/IEC 42001** necesarias para que las organizaciones desplieguen sistemas de IA en Google Cloud con confianza total.



Contacto: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI